

кейс КРОК

Сканер утечек в коде

// DevSecOps
// Secure Coding



// в какой области решаем проблему

// безопасная разработка (Secure Coding)

// DevSecOps

// автоматизация процессов обеспечения информационной безопасности в разработке ПО

Контекст: КРОК работает с комплексной экспертизой в области построения и развития инфраструктуры, внедрения информационных систем, разработки программных решений и сервисной поддержки.

// проблема и стейкхолдеры

Случайное попадание чувствительных данных в исходный код или конфигурационные файлы

Риск публикации секретов в системах контроля версий или публичных репозиториях

Сложность контроля безопасности в больших проектах и командах при ручной проверке кода

Недостатки автоматизированных инструментов для анализа кода и выявления потенциальных утечек секретов

// разработчики ПО // DevOps-инженеры // специалисты по ИБ

// тимлиды в разработке // инженеры сопровождения инфраструктуры

// существующие решения

- GitLeaks, TruffleHog, detect-secrets и аналоги
- Встроенные механизмы сканирования секретов в системах контроля версий
- Интеграция проверок в CI/CD-пайплайны
- Использование систем управления секретами (HashiCorp Vault, AWS Secrets Manager, GitLab CI variables)
- Применение DLP-подходов для контроля утечек чувствительной информации
- Внедрение практик Shift-Left DevSecOps
- Ручной контроль в рамках code review

Что будет, если не решать **проблему**:

Попадание секретов в исходный код может привести к несанкционированному доступу к инфраструктуре, утечке данных, компрометации сервисов, финансовым потерям и репутационным рискам. Подобные инциденты регулярно происходят даже в крупных компаниях и часто становятся причиной серьезных инцидентов.

// ожидаемое решение

Рабочий прототип **инструмента для автоматизированного поиска секретов** и чувствительных данных в исходном коде проекта с формированием отчета о потенциальных утечках

Ключевые **функциональные требования**:

- сканирование файлов проекта (исходный код, конфигурационные файлы, скрипты и т.п.);
- поиск потенциальных секретов по типовым паттернам (API-ключи, токены доступа, приватные ключи, строки, похожие на base64-закодированные данные);
- определение уровня критичности обнаруженной находки;
- формирование отчета, содержащего: путь к файлу, номер строки, тип обнаруженного секрета, уровень риска.

// ожидаемое решение

Рабочий прототип **инструмента для автоматизированного поиска секретов** и чувствительных данных в исходном коде проекта с формированием отчета о потенциальных утечках

Дополнительно приветствуется:

- поддержка различных типов файлов;
- настройка пользовательских правил поиска;
- рекомендации по устранению найденных проблем (например, перенос секретов в переменные окружения или систему управления секретами).

Решение должно работать **локально** и не требовать подключения к внешним сервисам. Формат реализации (CLI-утилита и/или веб-интерфейс) выбирается участниками самостоятельно.

ОТВЕТИМ НА ВСЕ ВАШИ ВОПРОСЫ

текстовое
описание кейса
ищи здесь

